Cybersecurity Daily Newsletter

Vol. 006 | 2026-10-17 09:00 WIB

Top 5 Highlights

- BeyondTrust Remote Support Zero-Day Continues Trend of Exploited Edge Bugs
- Critical BlockStrap flaw lets hackers run code on Magento servers
- Fake Claude, ChatGPT Attacks Surge, Putting Developers at Risk
- BeyondTrust zero-day exploited by China-linked group Armory Castle
- How SentinelOne Blocked APT29's CaptiveCrunch Campaign

Threat Intelligence (10)

01. Fake Claude, ChatGPT Attacks Surge, Putting Developers at Risk

Campaigns that impersonate popular AI brands are on the rise, and they typically use ClickFix-like tactics to target unsuspecting enterprise employees.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://www.darkreading.com/application-security/fake-claude-chatgpt-attacks-developers-risk

02. How SentinelOne Blocked APT29's CaptiveCrunch Campaign

Learn how SentinelOne's Static AI blocked APT29's CaptiveCrunch campaign on the endpoint, stopping local DNS poisoning and captive portal network lures.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://www.sentinelone.com/blog/how-sentinelone-blocked-apt29-s-captivecrunch-campaign/

03. KGB RAT malware uses psychological tactics to scare and steal from Windows users

A new malware strain named KGB RAT is weaponizing fear tactics, including fake Blue Screens of Death and jump scares, to target Windows users.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://www.scworld.com/brief/kgb-rat-malware-uses-psychological-tactics-to-scare-and-steal-from-windows-users

04. Attackers Tampered with AOMEI Backupper's Update Servers for Minutes to Deliver a Backdoor

Attackers repeatedly changed the files that AOMEI Backupper fetches from the vendor's own update servers, in windows of five to ten minutes at a time between May and July 2026, so that any copy of the Windows backup program that checked for an update during one of those windows would download and run a backdoor. Google Threat Intelligence Group, Mandiant, a…

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://thehackernews.com/2026/10/attackers-tampered-with-aomei.html

05. UAT-11985 Uses Fake Event Invites to Target Taiwan Research Affiliates With Google AitM Phishing

Cybersecurity researchers have disclosed details of an advanced persistent threat (APT) spear-phishing campaign that has targeted individuals affiliated with Taiwan research organizations to direct victims to an adversary-in-the-middle (AitM) phishing framework designed to harvest their Google account credentials and multi-factor authentication (MFA) codes.…

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: https://thehackernews.com/2026/10/uat-11985-uses-fake-event-invites-to.html

06. Continuous accountability for Verified bots

Identity alone doesn't guarantee a bot will behave responsibly. We are introducing a system to continuously evaluate whether Verified bots honor site preferences, like robots.txt and HTTP 429s, ensuring they remain accountable over time.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://blog.cloudflare.com/verified-bots-accountability/

07. Hackers disguise phishing as promising business opportunities

Attackers are breaking into business email accounts with short messages asking whether a company can quote on an upcoming project, the kind of request sales and procurement staff answer every week. Cadence Riddle, a cybersecurity researcher at Fortra, tracked a 12-fold increase in malicious emails mentioning “RFQ” (request for quotation) between October 202…

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: https://www.helpnetsecurity.com/2026/10/16/rfq-phishing-emails-sales-procurement-staff/

08. DORA TLPT Requirements Explained: Where Threat Intelligence Fits

The DORA TLPT requirements push selected EU financial entities beyond standard penetration testing. TLPT must be based on realistic threat scenarios, relevant threat actors, and current intelligence about how attacks are actually carried out. That makes threat intelligence a core part of the process. It helps define what should be tested, which TTPs matter,…

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://any.run/cybersecurity-blog/dora-tlpt-requirements-explained/

09. AI Decision Models and Their Impact on AI SOC Platforms

In the space of a month, a new category of AI model went from nonexistent to everywhere. TypeSafe AI released Jev on September 15 and called it a System One model, a nod to Kahneman's fast, intuitive thinking. OpenAI announced its own Decisions API at DevDay and opened a public beta on October 6. Cribl published cribl-decision, an open LoRA adapter you can…

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://thehackernews.com/2026/10/ai-decision-models-and-their-impact-on.html

10. [+24h Old] Malware evasion made easier with AI - but behavior still gives it away

Fresh research suggests recent panic over AI-generated malware may be overblown. Last month Anthropic detailed how Russia-linked cyberespionage group Midnight Blizzard used Claude to rebuild malware each time security tools flagged its backdoor as malign. “We observed GTG-20006 operate through customized AI-driven workflows that automated much of their oper…

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: https://www.csoonline.com/article/4235447/malware-evasion-made-easier-with-ai-but-behavior-still-gives-it-away.html

Latest Vulnerabilities (10)

01. BeyondTrust Remote Support Zero-Day Continues Trend of Exploited Edge Bugs

Ivanti, Cisco, and Palo Alto Networks all had vulnerabilities in edge devices come under fire this week. Now BeyondTrust joins the group.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.darkreading.com/endpoint-security/beyondtrust-remote-support-exploited-edge-bugs

02. Critical BlockStrap flaw lets hackers run code on Magento servers

Researchers warn that hackers could soon exploit a maximum-severity vulnerability (CVE-2026-103849) affecting Magento and Adobe Commerce, potentially allowing them to execute arbitrary PHP code on store servers. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.bleepingcomputer.com/news/security/critical-blockstrap-flaw-lets-hackers-run-code-on-magento-servers/

03. BeyondTrust zero-day exploited by China-linked group Armory Castle

Chinese group tied to at least three other major exploits over the past few weeks.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.scworld.com/news/beyondtrust-zero-day-exploited-by-china-linked-group-armory-castle

04. Researchers Demonstrate OpenBSD Root Exploit Chaining 37-Year-Old Shared-Memory Bug

A local privilege escalation exploit published today gains root on OpenBSD 7.9 by chaining a roughly 37-year-old integer overflow with a separate kernel flaw, bypassing OpenBSD's KARL kernel-address randomization and its SMAP and SMEP hardware protections. Security firm Calif, which found and reported the flaws, published a detailed writeup and full proof-o...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://thehackernews.com/2026/10/researchers-demonstrate-openbsd-root.html

05. Top 5 Initial Access Threat Vectors Observed by Unit 42 in September 2026

Unit 42 details the top initial access vectors adversaries use to breach organizations, led by edge exploits, credential abuse and phishing The post Top 5 Initial Access Threat Vectors Observed by Unit 42 in September 2026 appeared first on Unit 42 .

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://unit42.paloaltonetworks.com/top-5-initial-access-vectors-september-2026/

06. New PEERSTITCH malware exploits Fortinet flaw for covert communication

A sophisticated threat actor was observed exploiting a security vulnerability in Fortinet FortiOS to deploy a novel memory-resident ARM64 malware known as PEERSTITCH.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.scworld.com/brief/new-peerstitch-malware-exploits-fortinet-flaw-for-covert-communication

07. Hallucinated domain in official OpenAI skill underscores AI supply chain risks

Researchers have discovered a first-of-its-kind supply-chain vulnerability in OpenAI's official skills repository. OpenAI maintains an official GitHub repository of skills that teach AI agents how to work with various platforms and services. As an official skill, these components are often given an implicit level of trust because they are contributed or vet…

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.csoonline.com/article/4236659/hallucinated-domain-in-official-openai-skill-underscores-ai-supply-chain-risks.html

08. Networking problems after the October 2026 Windows update? NTLM might be to blame

Legacy protocol is going to be axed, and enforcement by default will highlight how migration is going

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.theregister.com/security/2026/10/16/networking-problems-after-the-october-2026-windows-update-ntlm-might-be-to-blame/5303503

09. Xbow spent $40K on AI and cracked Google Chrome wide open

A chain of vulnerabilities in Google's Chrome browser could have enabled researchers to take control of one billion Windows machines worldwide - and it cost them just $40,000 in AI compute time to discover it. Researchers at Xbow USA worked for six days on developing the exploit , which earned them a $250,000 bug bounty from Google, the first under the new…

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.csoonline.com/article/4236599/xbow-spent-40k-on-ai-and-cracked-google-chrome-wide-open-2.html

10. In Other News: ICS-Sniper Attack, Hacking XWorm Malware Operators, $250k Chrome Exploit

Noteworthy stories that might have slipped under the radar: BofA adds 1,000 patching contractors, KGB RAT pairs data theft with jump scares, and Langflow flaw under attack. The post In Other News: ICS-Sniper Attack, Hacking XWorm Malware Operators, $250k Chrome Exploit appeared first on SecurityWeek .

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.securityweek.com/in-other-news-ics-sniper-attack-hacking-xworm-malware-operators-250k-chrome-exploit/

Data Breach & Cybercrime (10)

01. The Good, the Bad and the Ugly in Cybersecurity - Week 42 (2026)

Authorities arrest cyber exec for extortion, cellular implant in Ledger wallets leaks seed phrases, and hackers heat French supermarket fridges to 50°C.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.sentinelone.com/blog/the-good-the-bad-and-the-ugly-in-cybersecurity-week-42-8

02. When Your Ransomware Negotiator Works for the Other Side

The shocking arrest of a well-known ransomware negotiator reveals the critical need for vendor program oversight.

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: https://www.darkreading.com/cyber-risk/when-your-ransomware-negotiator-works-other-side

03. When AI Agents Commit Breaches, Humans May Not Be Held Liable

As agents escape containment and access external systems, responsibility remains human. Accountability, however, is much less settled.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.darkreading.com/insider-threats/ai-agents-breaches-humans-liable

04. Ransomware Gangs Increasingly Turn to Threats of Physical Violence to Extort Payments

New report warns that threats of violence against employees of organizations hit by ransomware are on the rise as attackers find new ways to guarantee payments

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: https://www.infosecurity-magazine.com/news/ransomware-threats-physical/

05. Burger King Japan data breach exposes 11 million customer records

Burger King Japan, the Japanese subsidiary of global fast-food giant Burger King, disclosed a major data breach after attackers accessed a server containing 11.18 million customer records. […]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.bleepingcomputer.com/news/security/burger-king-japan-data-breach-exposes-11-million-customer-records/

06. “Spray and pray” job applications could make it harder for you to spot a scam

Sending out lots of job applications without keeping track could make a scammer’s message look like a reply you’ve been waiting for.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.malwarebytes.com/blog/news/2026/10/spray-and-pray-job-applications-could-make-it-harder-for-you-to-spot-a-scam

07. Scammers clone candidates’ voices to steal cash and voter data ahead of 2026 midterms, FBI warns

Three weeks before Americans vote in the 2026 midterm election, fraudsters are borrowing candidate names, logos and slogans to collect fake donations and harvest personal data, the FBI warned. “The FBI warns the public that scammers could exploit the 2026 US Midterm Election to perpetrate financial fraud schemes,” reads the public service announcement, whic…

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.helpnetsecurity.com/2026/10/16/usa-2026-midterm-election-scams/

08. [+24h Old] User refused to change her password because everyone already knew it

School staff seemed to be trying to get ransomware - for a second time

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: https://www.theregister.com/security/2026/10/16/user-refused-to-change-her-password-because-everyone-already-knew-it/5301864

09. [+24h Old] F-Secure Launches Victim-First Scam Encyclopedia Covering 50+ Types of Consumer Fraud

Built from decades of threat intelligence research, the new resource explains scams from the victims' perspective and tracks emerging forms of cyber crime.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.darkreading.com/threat-intelligence/f-secure-launches-victim-first-scam-encyclopedia-covering-50-types-of-consumer-fraud

10. [+24h Old] Android gets AI defenses against messaging scams, fake calls

Google announced new AI-powered defenses against scam messages and call-forwarding abuse on Android, currently rolling out to eligible devices. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.bleepingcomputer.com/news/security/android-gets-ai-defenses-against-messaging-scams-fake-calls/